Secure Software design: Vulnerability, Threat and Risk

- Assets, key characteristics of assets & example of cyber assets
- Vulnerability, examples. types of vulnerability, CVE & CVSS
- Threat, examples, types of threats, common types of cyber threats
- Risk, types of risk, Example of cyber incidents, Risk management.
- Differences between vulnerability, Threat and risk

Assets

Assets

- An asset is a resource owned or controlled by a person or business that is expected to provide a future benefit or generate income.

or

- Assets are defined as anything of value that the business wants to protect. This can include people, information or data, intellectual property, and physical property.

- Protecting assets is crucial for financial security and peace of mind, shielding hard-earned wealth from potential risks like lawsuits, creditors, and unforeseen circumstances.

- Cyber assets encompass all digital and physical resources that an organization uses and that require cybersecurity protection.

Key Characteristics of an Asset

- **Ownership/Control:** An asset is something that a person or business owns or controls.

- **Future Benefit:** It is expected to provide future economic benefits, such as cash flow, reduced expenses, or increased sales.

- **Tangible or Intangible:** Assets can be physical, like buildings or machinery, or non-physical, like patents or trademarks.

Examples of Cyber Assets

- **Hardware:** Servers, computers, network devices, endpoint devices.
- **Software:** Operating systems, applications, software libraries, code repositories.
- **Data:** Databases, documents, user credentials, sensitive information.
- **Network:** Network infrastructure, cloud services, APIs.
- **Other:** Identities (users, accounts), devices, cloud configurations, and more.

Vulnerability, Threat and Risk

Despite having different meanings, the terms threat, vulnerability, and risk are often used together. Threats are possibility of something negative to happen, vulnerabilities are flaws that can be used against you, and risks are the possible outcomes of these exploits.

Vulnerability

- Vulnerability is a weakness or flaw in a system, application, or network that can be exploited by a threat.

or

- A vulnerability is a flaw in a system's design, security procedures, internal controls, etc., that can be exploited by cybercriminals.

or

- A vulnerability is a weakness, flaw, or other shortcoming in a system (infrastructure, database, or software), but it can also exist in a process, a set of controls, or simply just the way that something has been implemented or deployed.

- **Identifying vulnerabilities is similar to answering the question, "How could harm occur?"**

Vulnerability

- A vulnerability is a weakness or defect in design, implementation, integration, operation or utilization of asset.

- CISA (The Cybersecurity and Infrastructure Security Agency) defines a vulnerability -

"***as a set of conditions that may lead to an implicit or explicit failure of the confidentiality, integrity, or availability of an information system***."

Vulnerability: Examples

- **Example 1**

❖ A vulnerability is leaving your car unlocked in a public parking lot. Leaving the doors unlocked does not necessarily mean harm will occur, but it is an opening for someone to go through your car.

- **Example 2**

❖ include outdated software, unpatched software, weak passwords, misconfigured network settings, misconfigured firewalls and human errors like phishing attacks.

Types of Vulnerability

Vulnerabilities could be of many types, based on different criteria, some of them are:

- **Network -** Network vulnerability is caused when there are some flaws in the network's hardware or software.
- **Operating system -** When an operating system designer designs an operating system with a policy that grants every program/user to have full access to the computer, it allows viruses and malware to make changes on behalf of the administrator.
- **Process -** Specific process control can also cause vulnerabilities in the system.
- **Physical Vulnerabilities:** Unprotected hardware, stolen devices, or unauthorized access to servers.

Types of Vulnerability

- **Software failures:** During the development process, bugs may arise that are not identified and corrected, leading to security gaps. Inadequate designs and implementations can introduce flaws that adversaries exploit in attacks such as unauthorized access, privilege escalation, and lateral movement.
- **Hardware failures:** Vulnerabilities in physical components are usually difficult to remediate, requiring physical replacement. Design flaws in processors, firmware bugs, and insecure hardware configurations can create long-term security risks.
- **Human factors:** These can originate from insufficient training, unmapped faulty processes, and a lack of security awareness. Misconfigurations, excessive permissions, or unnecessary services provide entry points for attackers, increasing the risk of data breaches and system compromises.

Types of Vulnerability

- **Technical vulnerabilities** - like bugs in code or an error in some hardware or software. in 2022, according to Positive Technologies, 72% of vulnerabilities were related to flaws in web application code.

- **Human vulnerabilities** - such as employees falling for phishing, smishing (Smishing is a type of phishing attack conducted via text messages), Quishing or other common attacks. The goal of 85% of these attacks is data theft.

Why Software Vulnerabilities Matter?

- When a process reads input from attacker, the process may be exploited if it contains vulnerabilities.
- When an attacker successfully exploits a vulnerability, he can
  - **Crash programs: Compromises availability**
  - **Execute arbitrary code: Compromises integrity**
  - **Obtain sensitive information: Compromises confidentiality**

- Software vulnerability enables the attacker to run with privileges of other users, violating desired access control policy

Common vulnerability and exposure (CVE)

- Common Vulnerabilities and Exposures (CVE) are a set of security threats that are included in a reference system that outlines publicly known risks.
- The CVE threat list is maintained by the MITRE Corporation, a nonprofit organization that runs federal government-sponsored research and development centers.
- CVE is sponsored by the U.S. Department of Homeland Security's National Cyber Security Division (NCSD).
- CVE's main goal is to help organizations improve their security defenses. It does this by identifying and providing a catalog of software or **firmware** vulnerabilities and making it available as a free dictionary.

Vulnerabilities vs Exposures

- A vulnerability is a **flaw** in software code that cyber attackers can use to access a computer system and carry out unauthorized actions while posing as a legitimate user.

- Attackers may use vulnerabilities to execute code, gain access to system memory, install various forms of malware, and steal, delete, or alter sensitive data.

- **An exposure is different. It is a mistake in software code or configuration that gives an attacker access to a system or network. Data breaches, data leaks, and the sale of personally identifiable information (PII) on the dark web can all result from exposures.**

How to calculate vulnerability?

- Evaluate the effectiveness of security measures and controls in place.
- Then, assess the strength of the security systems, access controls, and training programs.
- Identify any vulnerabilities discovered through assessments or audits.
- **The CVSS (Common Vulnerability Scoring System) calculator assesses the severity of vulnerabilities by providing a numerical score based on various metrics. This score helps organizations prioritize vulnerabilities based on their potential impact and exploitability.**

Common Vulnerability Scoring System (CVSS)

- The Common Vulnerability Scoring System (CVSS) is a widely used framework for assessing the severity of software vulnerabilities.
- It provides a numerical score, ranging from 0 to 10, representing the potential impact of a vulnerability, helping organizations prioritize remediation efforts.
- Purpose:
  - **Severity Assessment:** CVSS helps determine how dangerous a vulnerability is.
  - **Prioritization:** It allows organizations to prioritize which vulnerabilities to address first, based on their severity.
  - **Communication:** CVSS provides a standardized way to communicate the severity of vulnerabilities, making it easier for different teams and organizations to understand and address them.

CVSS Relationship to CVE

- CVSS is used in conjunction with the Common Vulnerabilities and Exposures (CVE) glossary, which is a list of publicly known security vulnerabilities.

- CVE identifies and catalogs vulnerabilities, while CVSS provides a numerical score to indicate their severity.

- The National Vulnerability Database (NVD) provides CVSS scores for CVE records.

Qualitative Severity Ratings

CVSS v2.0 Ratings		CVSS v3.x Ratings		CVSS v4.0 Ratings	
Severity	**Severity Score Range**	**Severity**	**Severity Score Range**	**Severity**	**Severity Score Range**
		None*	0.0	None*	0.0
Low	0.0-3.9	Low	0.1-3.9	Low	0.1-3.9
Medium	4.0-6.9	Medium	4.0-6.9	Medium	4.0-6.9
High	7.0-10.0	High	7.0-8.9	High	7.0-8.9
		Critical	9.0-10.0	Critical	9.0-10.0

CVSS vs. CVE

- The main difference between CVSS and CVE lies in their roles. CVE (Common Vulnerability Enumeration) gives unique identifiers to specific security vulnerabilities, making them easier to track.

- CVSS (Common Vulnerability Scoring System) provides a score that shows how severe each CVE is. For example, the Heartbleed vulnerability (CVE-2014-0160) has a CVSS score 7.5, indicating high severity.

Threat, cyber Threat, Attack vector and attack surface

Threat

- A potential danger or adverse event that can exploit a vulnerability to cause harm like data loss or system failure.

or

- A cyber threat is a malicious act that seeks to steal or damage data or discompose the digital network or system.

or

- Anything that could exploit a vulnerability, which could affect the confidentiality, integrity or availability of your systems, data, people, and more.

or

- A threat is any potential danger or harmful event that can exploit a vulnerability and cause harm to a system, organization, or individual.

- **Identifying threats is akin to answering the question, “Who or what could cause harm?”**

Examples

- **House:**
  - ❖A house and its contents would correctly be characterized as assets. If the front door is left unlocked/broken locks, this would be characterized as vulnerabilities.
  - ❖ If a burglar was aware of the broken locks and intended to exploit them, then he or she would be a threat.

- **Car:**
  - ❖**A car, the owner of the car did not lock their door, so a carjacker could exploit the opportunity. This means the threat is human-made and deliberate.**

Types of Threat

Threats could be of 3-types, which are as follows:

- **Intentional -** Malware, phishing, and accessing someone's account illegally, etc. are examples of intentional threats.
- **Unintentional -** Unintentional threats are considered human errors, for example, forgetting to update the firewall or the anti-virus could make the system more vulnerable.
- **Natural -** Natural disasters can also damage the data, they are known as natural threats.
- Thus, threats can either be natural or human-made and accidental or deliberate.

Common Sources of Cyber Threats

Here are several common sources of cyber threats against organizations:

1. **Nation states**—hostile countries can launch cyber attacks against local companies and institutions, aiming to interfere with communications, cause disorder, and inflict damage.
2. **Terrorist organizations**—terrorists conduct cyber attacks aimed at destroying or abusing critical infrastructure, threaten national security, disrupt economies, and cause bodily harm to citizens.
3. **Criminal groups**—organized groups of hackers aim to break into computing systems for economic benefit. These groups use phishing, spam, spyware and malware for extortion, theft of private information, and online scams.
4. **Hackers**—individual hackers target organizations using a variety of attack techniques. They are usually motivated by personal gain, revenge, financial gain, or political activity.
5. **Malicious insiders**—an employee who has legitimate access to company assets, and abuses their privileges to steal information or damage computing systems for economic or personal gain. Insiders may be employees, contractors, suppliers, or partners of the target organization.

Common threat categories facing modern organizations

- **Adversarial threats**—including third-party vendors, insider threats, trusted insiders, established hacker collectives, privileged insiders, ad hoc groups, suppliers, corporate espionage, and nation-states. This category also includes malicious software (malware) created by any of these entities. Large organizations mitigate these threats by establishing a security operations center (SOC) with trained security staff and specialized tooling.
- **Natural disasters**—hurricanes, floods, earthquakes, fire, and lightning can cause as much damage as a malicious cyber attacker. A natural disaster can result in loss of data, disruption of services, and the destruction of an organization's physical or digital resources. The threat of natural disaster can be minimized by distributing an organization's operations over multiple physical sites or using distributed cloud resources.
- **System failure**—when a system fails, it may cause data loss and also lead to a disruption in business continuity. Make sure that your most critical systems are running on high-quality equipment, have redundancy in place to ensure high availability, are backed up, and your providers offer timely support.
- **Human error**—any user may accidentally download malware or get tricked by social engineering schemes like phishing campaigns. A storage misconfiguration may expose sensitive data. To prevent and mitigate these threats, you should establish an employee training program and enforce strong security controls. For example, use password managers and monitor critical systems for misconfigurations.

Some common cyber threats

- **Malware**
- **Phishing**
- **Denial-of-Service (DoS)/DDoS Attacks**
- **Ransomware**
- **Man-in-the-Middle (MitM) Attacks**
- **SQL Injection**
- **Insider Threats**
- **Zero-Day Exploits**
- **Data Breaches**
- **DNS spoofing**
- **Brute force attacks**
- **Trojan horses**

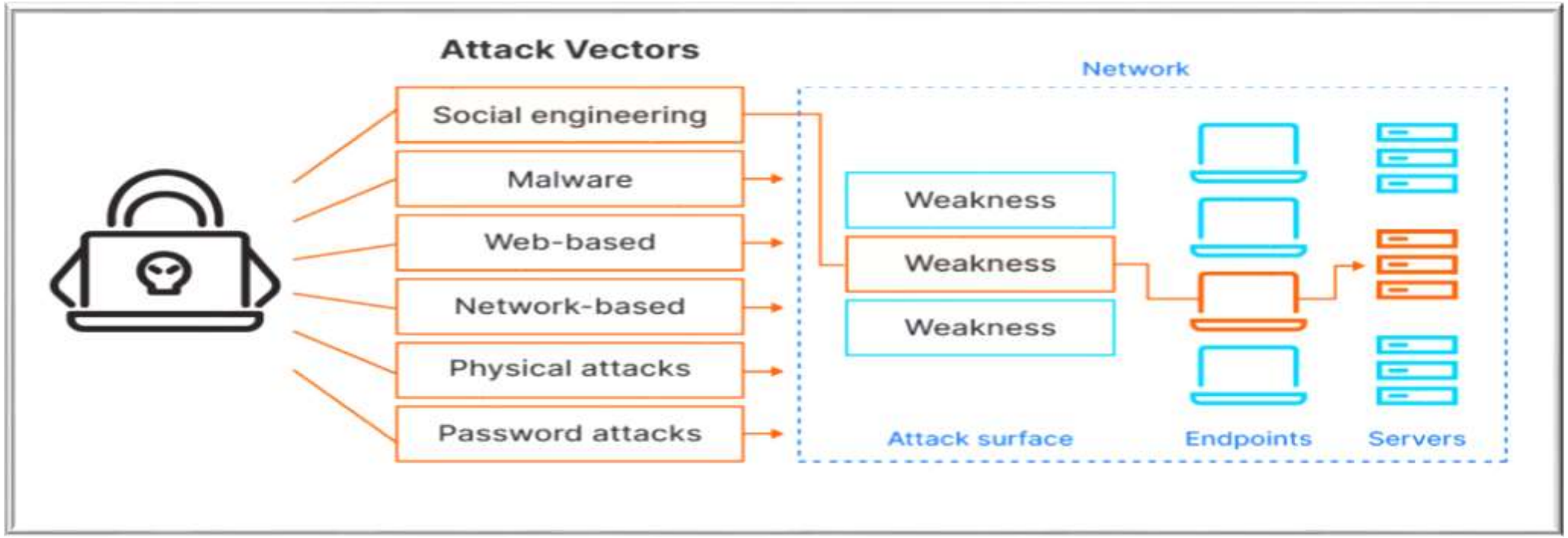
Attack vectors and attack surface

Attack Vectors are potential pathways into sensitive resources.

An Attack Surface is the sum of all attack vectors on a digital surface.

Attack vectors

- Attack vectors are the paths or methods that cybercriminals use to gain unauthorized access to a system, network, or application.
- Attack vectors allow hackers to gain unauthorized access to operating systems or application. For example, an attacker may exploit unpatched software to compromise a system or deploy malware to infect it.



Different types of attack vectors



Malware Attacks

Viruses
Worms
Trojans
Ransomware
Cryptojacking

Spyware
Adware
Fileless malware
Rootkits



Social Engineering

Baiting
Pretexting
Phishing
Vishing (voice phishing)

Smishing
Piggybacking
Tailgating



Man-in-the-Middle

Wi-Fi eavesdropping
Email hijacking

DNS spoofing
IP spoofing
HTTPS spoofing



Denial-of-Service

HTTP flood DDoS
SYN flood DDoS
UDP flood DDoS
ICMP flood
NTP amplification



Injection

SQL injection
Code injection
OS command injection
LDAP injection

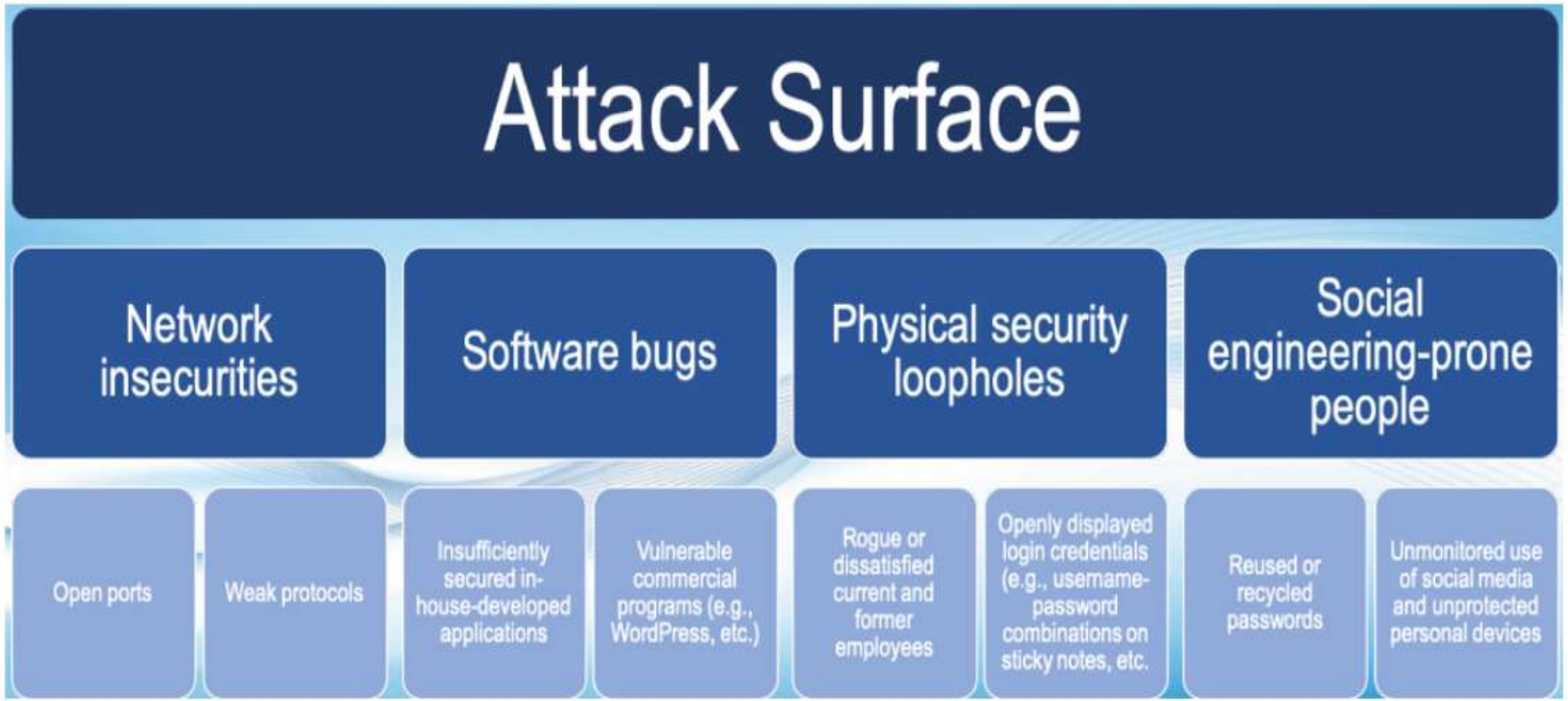
XML eXternal Entities (XXE)
Injection Cross-Site Scripting (XSS)

What is an Attack Surface?

- **Attack vectors:**
  - ✓These are the specific tools and methods attackers use to exploit vulnerabilities in a system.

- **Attack surface:**
  - ✓The attack surface is the aggregate of exploitable points in the network that could be attacked—that overall picture of **multiple cyber security attack vectors** that could be used to exploit a single system or network.
  - ✓ It includes any **hardware, software, interfaces, and human factors** that could be targeted.
  - ✓Examples include **open ports, web applications, network devices, user accounts, and even physical access points**.

Attack surface



Social engineering attack vectors

Cyber attack vectors can be classified based on attacker methodology and tools. Here are some Social engineering attack vectors exploit human behaviour.

- **Phishing**: These deceptive emails or messages steal information or gain access.
- **Pretexting:** Fabricated scenarios to steal information.
- **Baiting:** Enticing victims to click links to take other unsecured actions with offers or rewards.
- **Tailgating:** Following someone into a restricted area.

Risk and cyber security risk

Example of Risk: House

- A house and its contents would correctly be characterized as assets. If the front door is **left unlocked/broken locks**, this would be characterized as vulnerabilities.
- If a burglar was aware of the broken locks/ unlocks and intended to exploit them, then **he or she** would be a **threat**.

- **And the chance or likelihood of the burglar (he/she) entering in and stealing jewelry, electronics, or other possessions would be the risk. In this case, the difference between vulnerability and risk should be clear.**

Example of Risk: House

- Similarly, a car or truck would be an asset. If the window is left **rolled down** while the owner goes into the grocery store, that would be a vulnerability.

- A **passerby** in the parking lot that sees the **downed-window** and notices some coins/dollars in a cupholder would be a **threat**.

- **And the value of those coins/dollars would be the risk involved to the owner of the car if they were to be stolen.**

Asset, vulnerability, Threat and risk



Risk comes with this universal truth: you cannot eliminate or entirely protect against all threats, no matter how advanced your systems are.

Example of cyber incidents

Here are five notable incidents:

1. Data breaches due to insider threats

- Two former Tesla employees leaked sensitive data, including Social Security numbers and contact details, of more than 75,000 individuals to a foreign outlet. The breach was an inside job—no fancy hacks; just people with access.

2. Ransomware attacks exploiting software vulnerabilities

- In mid-2023, the Clop ransomware gang exploited a known vulnerability in Progress Software's MOVEit Transfer product. The fallout was massive: 2,700+ organizations affected and nearly 100 million individuals impacted.

Example of cyber incidents

3. Network misconfigurations exposing sensitive data

- Separate from the exploit above, a misconfiguration in MOVEit Transfer left doors wide open to unauthorized access. The breach wasn't a result of malware or credential theft—it was preventable mismanagement.

4. Supply chain attacks compromising third-party vendors

- A zero-day in Fortra's ***GoAnywhere*** software was exploited by the same ransomware group and exposed 130+ organizations. The issue? A weak link in the supply chain became everyone's problem.

5. Denial of Service (DoS) attacks disrupting operations

- A bad update from CrowdStrike disrupted Microsoft systems worldwide. It wasn't a deliberate attack, but the result was just as damaging—critical outages across industries.

Types of Risks (based on attackers position)

There are two types of cyber risks, which are as follows:

1. **External -** External cyber risks are those which come from outside an organization, such as cyberattacks, phishing, ransomware, DDoS attacks, etc.

2. **Internal -** Internal cyber risks come from insiders. These insiders could have malicious intent or are just not be properly trained.

Types of Cyber Security Risks

There are several types of cyber security risks that businesses and individuals should be aware of:

- **Data breach risk:** When sensitive data (like customer info or financial records) is exposed or stolen.
- **Operational risk:** When an attack disrupts business operations, such as shutting down systems or halting services.
- **Financial risk:** Losses due to fraud, ransom payments, or penalties from non-compliance.
- **Reputational risk:** Damage to your brand image or customer trust after a cyber incident.
- **Compliance risk:** Failing to meet industry standards or legal regulations related to data protection.
- **Insider risk:** Risks coming from within the organization, like employee misuse or accidental data leaks

Risks vary depending on various factors

Risks vary depending on various factors

Cyber security risks vary depending on:

- **How exposed your systems are?,**
- **How valuable your data is?,**
- **How strong your defences are?,**

- For example, if you store customer data on an **outdated system** without regular updates, and **hackers** are actively exploiting such weaknesses, your cyber **security risk** becomes significantly high.

Risk calculation

- Once we know an asset's vulnerabilities and threats, we can determine how much risk is posed to the asset owner. This measure is the combination of the **likelihood that a threat exploits a vulnerability** and the scale of harmful consequences.

Risk = (Probability that a threat occurs) * (Cost to the asset owner)

- Despite the quantitative-looking nature of risk calculation, many risk analyses use qualitative ratings.

- This is because it can be extremely difficult to determine accurate probabilities and realistic costs, especially for intangible assets like trade secrets.

Another way of describing risk

- **Risk = (Threat x Vulnerability)**
- **Risk = Likelihood x Consequence**
- **Risk = Likelihood of Occurrence x Potential Impact to Asset Owner**
- Risk can be quantified as the probability of a threat succeeding multiplied by the value of a potential loss. An unpatched software system that could lead to a complete loss of an entire corporate data set is a massive risk. **Conversely, a photocopier that still has the default password in place poses a small risk.**
- Risk fluctuates based on a wide range of factors. Sometimes, something in the business, like a specific investment or strategic initiative changes the company's risk profile. Sometimes external factors, like a new interest in an industry or sector brings greater risk to a business.

Another way of describing risk

- Risk is commonly quantified using the formula -

  Risk = Threat x Vulnerability x Impact

- This formula quantifies risk by combining the probability of a threat event, a vulnerability that can be exploited, and the potential impact of that exploitation.

  - **Probability** refers to the chance that an event will occur
  - **Impact** measures the severity of its consequences

- **Risk, therefore, represents the likelihood that a threat will exploit a vulnerability in an asset, resulting in a specific impact.**

Factors Contributing to Cybersecurity Risks

1. **Increasing Sophistication of Cyberattacks:**
   - Attackers are continuously developing new techniques and tools, making it more challenging to defend against cyber threats.
2. **Evolving Threat Landscape:**
   - New cyber threats emerge regularly, requiring organizations to stay vigilant and adapt their security measures.
3. **Lack of Cybersecurity Awareness:**
   - Insufficient training and education among employees can lead to human errors that compromise security.
4. **Complexity of IT Infrastructure:**
   - Modern IT systems are increasingly complex, with numerous devices, applications, and networks, making it difficult to manage security.

Threats with associated risks

Threat Type	Threat	Exploit/Vulnerability	Exposed Risk
Human factor internal threat	Intruder	No security guard or controlled entrance	Theft
Human factor external threat	Hacker	Misconfigured firewall	Stolen credit card information
Human factor internal threat	Current employee	Poor accountability; no audit policy	Loss of integrity; altered data
Natural	Fire	Insufficient fire control	Damage or loss of life
Natural	Hurricane	Insufficient preparation	Damage or loss of life
Malicious external threat	Virus	Out-of-date antivirus software	Virus infection and loss of productivity
Technical internal threat	Hard drive failure	No data backup	Data loss and unrecoverable downtime

Vulnerability vs threat vs risk

Vulnerability vs threat vs risk

- These 3 fundamental cybersecurity concepts are related but have distinct meanings.
- Security experts define these 3 concepts in a variety of ways, and the terms threat and risk are sometimes used interchangeably.
- Each term can be thought of in reference to an asset or "something that needs to be protected."
  - A vulnerability is **a flaw or weakness** in an asset's design, implementation, or operation and management that could be exploited by a threat.
  - A threat is a **potential** for an agent **to exploit a vulnerability**.
  - A risk is the **potential for loss** when the threat happens.

Vulnerability vs threat vs risk

These terms are frequently used together, but they do explain three separate components of cybersecurity.

In short, we can see them as a spectrum:

- First, a **vulnerability** exposes your organization to threats.
- A **threat** is a malicious or negative event that takes advantage of a vulnerability.
- Finally, the **risk** is the potential for loss and damage when the threat does occur.

Differences between vulnerability, threat and risk

Feature	Vulnerability	Threat	Risk
Definition	A weakness in a system, process, or human behavior that can be exploited by a threat	A potential danger that can exploit a vulnerability to breach security and cause harm	The potential for loss or damage that arises from a threat exploiting a vulnerability
Nature	Static (exists whether or not it's exploited)	Dynamic (can change or evolve)	Consequence of a threat exploiting a vulnerability
Examples	Unpatched software, weak passwords, lack of employee training, misconfigured firewall	Malware, phishing attacks, denial-of-service attacks, insider threats, natural disasters	Data breach, financial loss, reputational damage, business disruption, legal liabilities
Management	Patching, hardening systems, implementing controls, etc.	Threat intelligence, security awareness training, incident response planning	Risk assessment, risk mitigation strategies, acceptance, or transfer (e.g., insurance)
Measurability	Can be quantified (e.g., number of open ports)	Can be assessed (e.g., likelihood and impact)	Can be measured in terms of financial loss, downtime, etc.